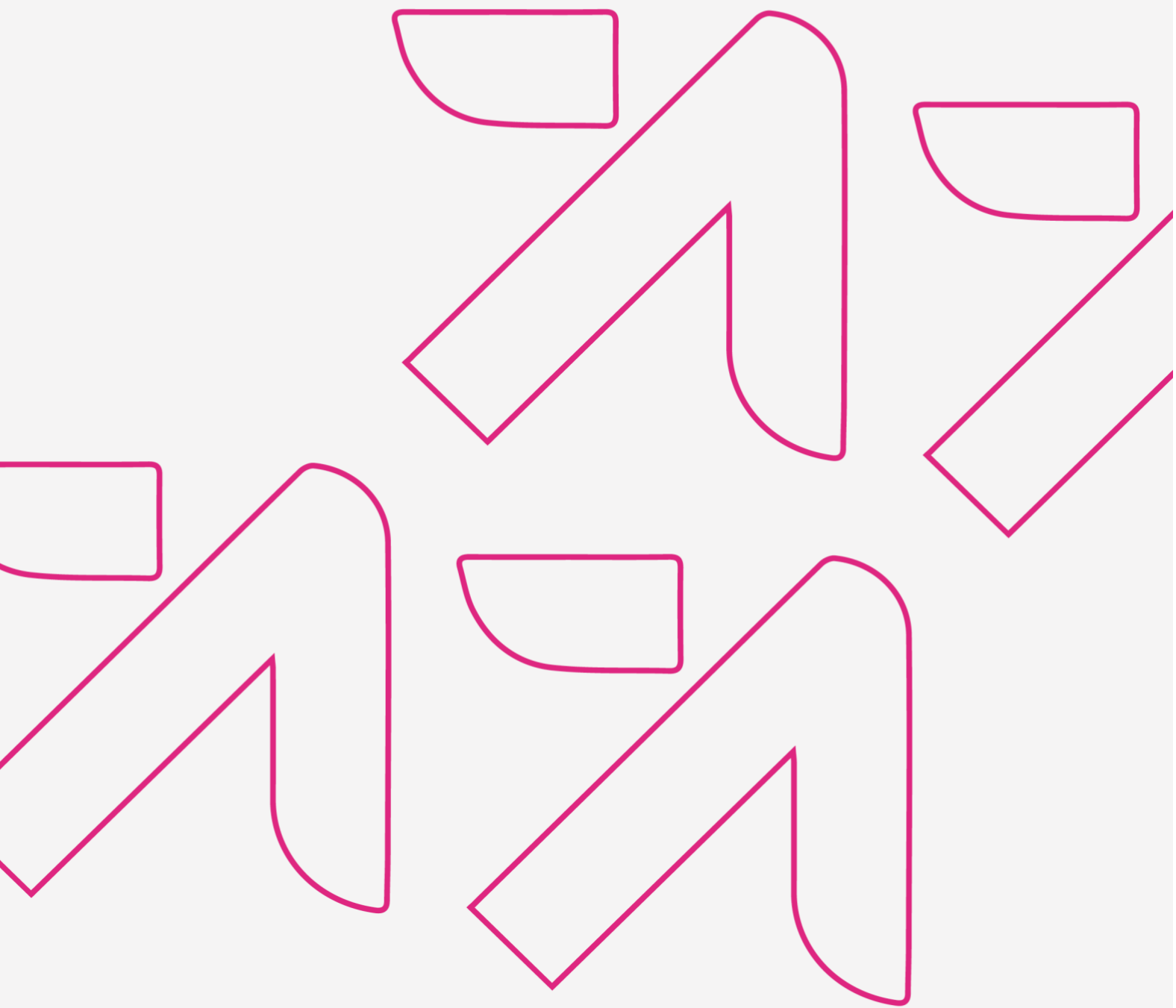




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT3. Hardening de sistemas operativos (Linux y Windows)

Encaje en el curso 2026/2027: esta unidad desarrolla el RA7 (bastionar el sistema en producción, tema 12) y toca el RA6 (instalación segura, tema 11) en lo relativo al cifrado.

1. Objetivo del hardening

El hardening consiste en reducir la superficie de ataque de un sistema operativo eliminando servicios innecesarios, aplicando configuraciones seguras, reforzando permisos y asegurando que el sistema esté preparado para resistir ataques básicos y avanzados.

Un sistema sin hardening es terreno fértil para escaladas de privilegios, movimientos laterales y explotación automatizada.

2. Principios generales de hardening

2.1. Mínimos servicios

Un sistema solo debe ejecutar los servicios estrictamente necesarios. Cuantos más servicios, más vectores de ataque.

2.2. Configuraciones seguras por defecto

La mayoría de sistemas vienen configurados para facilidad de uso, no para seguridad. El hardening revierte esa filosofía.

2.3. Parches y actualizaciones

Un sistema no parcheado es un sistema vulnerable. El ciclo de actualización debe ser continuo.

2.4. Control estricto de privilegios

Los usuarios deben tener exactamente los permisos necesarios, ni uno más.

2.5. Monitorización y auditoría

Si no se registra, no se puede detectar actividad maliciosa ni anomalías.

2.6. No partir de cero: guías y líneas base

Nadie bastiona de memoria. Se parte de una guía reconocida y se documentan las desviaciones:

- **CIS Benchmarks:** una guía por sistema y versión, con dos niveles de exigencia.
- **Guías CCN-STIC:** las de referencia en España y obligadas en el ámbito del ENS (por ejemplo, la serie 600 para Linux y la serie 500 para Windows).

- **Microsoft Security Baselines:** plantillas de GPO oficiales, dentro del Security Compliance Toolkit.
- **DISA STIG:** muy estrictas, habituales en defensa.

3. Hardening en Linux

3.1. Gestión de usuarios y permisos

- Eliminación de cuentas innecesarias.
- Uso de sudo con restricciones.
- Permisos mínimos en archivos críticos.
- Revisión de grupos y accesos.

3.2. Servicios y procesos

- Deshabilitar servicios no utilizados (systemctl disable).
- Detectar demonios innecesarios: FTP, Telnet, NFS, RPC antiguos.
- Reducir superficie en puertos abiertos.

3.3. Configuración del kernel (sysctl)

Ajustes típicos:

- Deshabilitar IP forwarding si no se usa.
- Proteger contra spoofing (filtrado de ruta inversa).
- Limitar paquetes ICMP.
- Habilitar protección de punteros y memoria (ASLR, kptr_restrict).

```
# /etc/sysctl.d/90-hardening.conf
net.ipv4.ip_forward = 0
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.icmp_echo_ignore_broadcasts = 1
net.ipv4.tcp_syncookies = 1
kernel.randomize_va_space = 2
kernel.kptr_restrict = 2
```

Se aplica con `sudo sysctl --system` y se comprueba con `sysctl` seguido del nombre del parámetro.

3.4. Seguridad SSH

- Deshabilitar acceso root.
- Forzar claves en lugar de contraseñas.
- Cambiar puertos no mejora seguridad, pero reduce ruido.
- Controlar hosts permitidos y protocolos.

3.5. Integridad del sistema

- AIDE u otras herramientas de integridad (Tripwire, o el módulo FIM de Wazuh).
- Alertas cuando cambian archivos críticos.

3.6. Control de acceso obligatorio

- **SELinux** (familia Red Hat) o **AppArmor** (Debian, Ubuntu) confinan cada servicio a lo que necesita, aunque se ejecute como root.
- Deben estar en modo enforcing. Desactivarlos «porque molestan» es uno de los errores más habituales.

3.7. Logs y auditoría

- Gestión de logs con journald/rsyslog.
- Activación de auditd para eventos relevantes.
- Rotación y retención de logs.

4. Hardening en Windows

4.1. Políticas de seguridad

Windows ofrece políticas integradas para reforzar el sistema:

- Bloqueo de cuentas por intentos fallidos.
- Reglas de contraseñas seguras.
- Restricciones de ejecución.

4.2. GPO (Group Policy Objects)

Las GPO permiten aplicar configuraciones a nivel corporativo:

- Deshabilitar servicios inseguros.
- Configurar firewall por defecto.
- Reforzar RDP.
- Controlar dispositivos USB.

4.3. Hardening de RDP

- Activar NLA (Autenticación a nivel de red).
- Forzar TLS.
- Limitar IPs permitidas.
- Uso de gateway o VPN.

4.4. Cuentas y privilegios

- Deshabilitar el administrador local o gestionarlo con Windows LAPS, que le pone una contraseña distinta y rotada en cada equipo.
- Separar cuentas de administrador y usuario.
- Permisos mínimos en carpetas sensibles.

4.5. Servicios y arranque

- Deshabilitar servicios legacy (SMBv1, Telnet, Remote Registry).
- Revisar aplicaciones que se ejecutan al inicio.
- Evitar software obsoleto.

4.6. Auditoría y logs

- Activar auditoría avanzada: acceso a archivos, autenticación, cambios de política.
- Revisar Windows Event Logs regularmente.
- Enviar logs a un SIEM o servidor centralizado.

5. Hardening transversal para ambos sistemas

5.1. Cortafuegos local

Configurar firewall nativo:

- Linux: nftables (el sucesor de iptables), o sus interfaces firewalld y ufw.
- Windows: Firewall de Windows con reglas específicas.

El principio: negar todo excepto lo necesario.

5.2. Antivirus y antimalware

- Windows: Microsoft Defender bien configurado es una buena base; en empresa se complementa con un EDR.
- Linux: no es obligatorio, pero útil en entornos mixtos.

5.3. Cifrado

- Discos cifrados (BitLocker, LUKS).
- Cifrado en tránsito para servicios.

5.4. Inventario y control de software

- Solo instalar software autorizado.
- Detectar binarios no firmados o sospechosos.

6. Auditorías de seguridad

El hardening no es un evento: es un proceso continuo. La auditoría sirve para validar que el sistema sigue cumpliendo los controles.

6.1. Herramientas

- Linux: Lynis, OpenSCAP.
- Multiplataforma: el módulo SCA de Wazuh, que compara cada equipo con el CIS Benchmark y da un porcentaje de cumplimiento.
- Windows: Policy Analyzer (Security Compliance Toolkit), Microsoft Defender for Endpoint, CLARA (CCN).
- Escáneres de vulnerabilidades: Nessus, OpenVAS.

6.2. Informe de auditoría

Incluye:

- Hallazgos.
- Severidad.
- Identificación del control afectado.
- Recomendaciones.
- Acciones correctivas.

7. Buenas prácticas finales

- Eliminar software preinstalado innecesario.
- Configurar autenticación multifactor en accesos críticos.
- Segregar redes de administración.
- Registrar absolutamente todo lo que afecte a seguridad.
- Automatizar donde sea posible (scripts, Ansible, GPO).

Para ampliar

- CIS Benchmarks (hay uno por sistema operativo y versión).
- Guías CCN-STIC: serie 600 (Linux y otros entornos) y serie 500 (Windows).
- Microsoft Security Compliance Toolkit y Security Baselines.
- Documentación de Lynis, OpenSCAP y del módulo SCA de Wazuh.